PENSE-BÊTE · RECOMMANDATIONS DE SÉCURITÉ

Directive NIS 2

01-40 NIS 2 - Directive européenne Cybersécurité des entités critiques — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

À RETENIR

1. La directive vise à harmoniser la cybersécurité dans l'UE en imposant des stratégies nationales et des obligations d'information.
2. La gouvernance repose sur des autorités compétentes, un point de contact unique et des CSIRT pour la gestion des menaces.
3. La supervision des entités essentielles inclut des pouvoirs d'inspection sur place et des sanctions financières importantes.

Dispositions générales et champ d'application

Notion	À retenir
Objet et finalité	Obtenir un **niveau commun élevé** de cybersécurité dans l'**UE** pour améliorer le **marché intérieur**. Impose **stratégies nationales**, **autorités compétentes**, **gestion des risques** et **obligations d'information**.
Champ d'application	**Moyennes/grandes** entités publiques ou privées de l'UE ; toute taille : entités critiques, réseaux publics, services de confiance, registres de domaines. **Exclus** : sécurité nationale, défense, répression, parlements, banques centrales.
Distinction entités	**Essentielles** : grandes entreprises hautement critiques, services de confiance qualifiés, registres, administration centrale. **Importantes** : autres entités des annexes I et II. Liste au **17 avril 2025**.
Relation actes sectoriels	Les **actes juridiques sectoriels de l'Union** priment si les mesures de **gestion des risques** ou de **notification d'incidents** ont un **effet équivalent** à la directive.

Gouvernance nationale et européenne

Notion	À retenir
Stratégie nationale	Adoption par l'État membre pour définir **objectifs**, **ressources** et **mesures réglementaires**. Inclut : **chaîne d'approvisionnement**, **vulnérabilités**, **éducation**, **formation** et **sensibilisation**.
Autorités et CSIRT	Désignation d'**autorités compétentes** (supervision), d'un **point de contact unique** (liaison transfrontière) et de **CSIRT** (menaces, incidents, alertes).
Gestion de crise	Désignation d'une **autorité de gestion des crises cyber**, adoption d'un **plan national de réaction**. Un **CSIRT** coordonne la **divulgation des vulnérabilités**. L'**ENISA** gère la **base de données européenne**.
Coopération Union	Institution d'un **groupe de coopération** (stratégique), d'un **réseau des CSIRT** (opérationnel) et du réseau **EU-CyCLONe** (incidents majeurs et crises).

Synthèse de la gestion des risques et obligations

Notion	À retenir
Gouvernance et responsabilité	**Organes de direction** : doivent approuver les mesures, superviser la mise en œuvre et peuvent être **responsables des manquements**. Formation obligatoire pour l'évaluation des risques.
Mesures de gestion des risques	Mesures **techniques, opérationnelles et organisationnelles** : approche **multirisque** (chaîne d'approvisionnement, continuité, chiffrement, hygiène). Inclure les vulnérabilités des **fournisseurs et prestataires directs**.
Obligations de signalement	Signalement au **CSIRT** ou **autorité compétente** : alerte précoce sous **24 heures**, notification détaillée sous **72 heures**, rapport final sous **1 mois**.
Certification et normalisation	Utilisation de produits/services TIC **certifiés** (schémas européens) possible. Recours encouragé aux **normes et spécifications** européennes et internationales pour la convergence.

Compétence et enregistrement

Notion	À retenir
Compétence territoriale	Entités : État membre d'**établissement**. Fournisseurs communications électroniques : État membre de **fourniture de services**. Fournisseurs numériques (cloud, centres de données) : État membre de l'**établissement principal dans l'Union**.
Registre et noms de domaine	L'**ENISA** tient le registre des services numériques critiques. Les registres de **premier niveau** maintiennent les données d'enregistrement et répondent aux demandes légitimes sous **72 heures**.

Supervision et exécution

Notion	À retenir
Principes généraux	Supervision **efficace** pour assurer le respect de la directive. Priorités fixées selon une **approche basée sur les risques**.
Entités essentielles	Pouvoirs : inspection sur place, contrôle à distance, audit régulier, demande d'informations. Sanctions : avertissements, instructions contraignantes, cessation du comportement, suspension de certification.
Entités importantes	Supervision principalement **ex post** (preuves ou non-conformité). Pouvoirs : inspection, audit et demande d'informations pour l'évaluation **ex post**.
Amendes administratives	Plafond d'**au moins 10 000 000 €** ou **2 %** du CA mondial (essentielles) ; **7 000 000 €** ou **1,4 %** (importantes) ; le montant le plus élevé est retenu.

Dispositions finales

Notion	À retenir
Transposition et abrogation	Adoption et publication des dispositions : au plus tard le **17 octobre 2024**. Abrogation de la directive **NIS 1** (UE 2016/1148) : effet au **18 octobre 2024**.
Réexamen	Par la Commission au plus tard le **17 octobre 2027**, puis tous les **36 mois**.

Pièges et confusions

- ⚠ Confondre la responsabilité des organes de direction qui est personnelle et directe avec une simple responsabilité de l'entreprise.
- ⚠ Oublier que la première alerte d'un incident doit être effectuée sous 24 heures.
- ⚠ Négliger l'obligation d'inclure la sécurité de la chaîne d'approvisionnement et des fournisseurs dans la gestion des risques.
- ⚠ Sous-estimer le montant des sanctions qui sont calquées sur le modèle du RGPD avec des plafonds en pourcentage du chiffre d'affaires mondial.

Sigles et définitions

Sécurité des réseaux et des systèmes d'information	capacité de ces systèmes à résister à tout événement compromettant la disponibilité, l'authenticité, l'intégrité ou la confidentialité des données ou des services
Incident	événement compromettant la disponibilité, l'authenticité, l'intégrité ou la confidentialité des données stockées, transmises ou traitées, ou des services offerts
Incident de cybersécurité majeur	incident causant des perturbations dépassant les capacités de réaction d'un État membre ou ayant un impact important sur au moins deux États membres
Cybermenace importante	menace susceptible d'avoir un impact grave sur les réseaux et systèmes d'information en causant un dommage matériel, corporel ou moral considérable
Gestion des incidents	actions et procédures visant à prévenir, détecter, analyser et contenir un incident ou à y répondre et à y remédier
Point d'échange internet	structure de réseau permettant l'interconnexion de plus de deux réseaux indépendants pour faciliter l'échange de trafic internet
DNS	système hiérarchique et distribué d'affectation de noms permettant l'identification des services et ressources internet
Fournisseur de services gérés	entité fournissant des services liés à l'installation, la gestion, l'exploitation ou l'entretien de produits et réseaux TIC via une assistance ou une administration active

Auto-test

1. Quel est le délai pour la première alerte d'un incident ?
2. Quelle entité gère la base de données européenne ?
3. Quel est le plafond d'amende pour une entité essentielle ?
4. Quelle est la date d'abrogation de la directive NIS 1 ?
5. Qui tient le registre des services numériques critiques ?

Réponses : **1.** sous 24 heures · **2.** l'ENISA · **3.** Au moins 10 000 000 € ou 2 % du CA mondial (le plus élevé). · **4.** 18 octobre 2024 · **5.** l'ENISA

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.